



MARIANO MARCOS STATE UNIVERSITY



BAGONG PILIPINAS

Cultivating Minds, Transforming Futures



Applied**HE**TM
PUBLIC UNIVERSITY RANKING: **ASEAN 2024**
RANK **2** AMONG PHILIPPINE SUCs



Rank 601-800 in the World
Rank 3 among Philippine SUCs

WURI | **Rank 101st-200th**
The WORLD UNIVERSITY
RANKINGS for INNOVATION

The MSR Model of Information Assurance

By:
Joshua L. Fernandez



MMSU



4-Star
QS Rating



Rank 601-800 in the World
Rank 3 among Philippine SUCs



Rank 101st-200th
The WORLD UNIVERSITY
RANKINGS for INNOVATION



Rank 2
in the Philippines

AppliedHETM
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

COLLEGE OF COMPUTING AND INFORMATION SCIENCES

Department of Computer Science

Maconachy-Schou-Ragsdale (MSR) Model

- In 2001, the MSR model...
 - » Three State of Information (Storage, Transmission, Processing)
 - » Three Essential Countermeasures (Availability, Integrity, Authentication)
 - » Five Basic Services (Availability, Integrity, Authentication, Confidentiality, Nonrepudiation)

MSR Model

The **MSR model** provides a comprehensive framework that aligns security measures with real-world applications of information assurance. It emphasizes securing data across different states (storage, transmission, and processing), while also focusing on essential countermeasures like availability, integrity, and authentication, and offering core services such as confidentiality and nonrepudiation to ensure a well-rounded, resilient security posture.

(MSR) Model

- » **Three State of Information (Storage)**
Storage: Data at rest, or **stored** data. This refers to information that is saved or archived in databases, files, or other storage media.

Example:

A company's **customer database** containing personal information, financial data, and account history. This data must be protected from unauthorized access or tampering while stored.

Shodan.io

SHODAN Explore Pricing Search

Search Engine for the Internet of Everything

Shodan is the world's first search engine for Internet-connected devices. Discover how Internet intelligence can help you make better decisions.

[SIGN UP NOW](#)

// EXPLORE THE PLATFORM

Beyond the Web

Websites are just one part of the Internet. Use Shodan to discover everything from power plants, mobile phones, refrigerators and Minecraft servers.

Monitor Network Exposure

Keep track of all your devices that are directly accessible from the Internet. Shodan provides a comprehensive view of all exposed services to help you stay secure.

Internet Intelligence

Learn more about who is using various products and how they're changing over time. Shodan gives you a data-driven view of the technology that powers the Internet.

Shodan.io

Familiar with God's eye from the fast and the furious movie?

God's Eye in real life. It offers:

- Search for Connected Devices
- Security Research
- Internet-Wide Scan
- Detailed Device Information
- Visualization and Data

MSR Model (transmission)

- **Transmission:** Data in motion, or **data being transferred** between systems, devices, or over a network. Data transmitted over networks can be intercepted or altered by attackers if not protected properly.
- **Example: Email communications** between a company and a client containing sensitive information like contracts or financial data.
- **Application:** Using **TLS/SSL encryption** for secure web browsing, **VPNs** for secure remote access, and **end-to-end encryption** in communication tools like WhatsApp.

Dehashed.com

Purpose: A database of exposed and breached personal information.

Use: Search for leaked personal information across various breaches. You can search using your email, phone number, or other identifiers.

MSR Model (Processing)

- **Processing:** Data in use or **actively being processed** by systems, software, or users. This includes data that is temporarily in memory while being analyzed, calculated, or manipulated.
- **Example: Real-time transactions** in an online banking system, where the data is being processed to check balances, transfer funds, or update records.
- **Application:** Ensuring **access control mechanisms** are in place, applying **data masking** to sensitive data, and using **secure processing environments**.

Google Hacking (Dorking)

- Refers to the use of **advanced search operators** in Google (or other search engines) to find information that is not easily accessible or intended to be public

Example:

filetype: pdf confidential

This would search for PDF files containing the word "confidential".

Google Hacking (Dorking)

- **Database Dumps:** Finding exposed backups or dumps of databases containing usernames, passwords, or other sensitive data.
“filetype:sql "insert into" password”
- **Unprotected Admin Interfaces:** Discovering admin or control panel login pages that are exposed to the public
“inurl:"/admin" intitle:"admin login”



MMSU

Five Basic Services

Availability: Ensures that data is accessible when needed, even in the case of system failures, attacks, or disasters.

- **Example:** A hospital's electronic health record system, where patient data must be available at any time for medical staff, even if there's a system malfunction or external attack.
- **Application:** Using **redundant servers, cloud storage, backup systems, and load balancing** to ensure constant access.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs





MMSU

Wayback Machine

 INTERNET ARCHIVE

WEBTEXTSVideosAUDIOSoftwareIMAGES

SIGN UP | LOG IN | UPLOAD

ABOUTBLOGPROJECTSHELPDONATECONTACTJOBSVOLUNTEERPEOPLE

Search the history of over 916 billion web pages on the Internet.

WayBackMachine

enter URL or keywords



Internet Archive is a non-profit library of millions of free texts, movies, software, music, websites, and more.

916B

43M

13M

13M

3M

1.2M

5.1M

269K

2.5M

Search

GO

Advanced Search

Archive News

Announcing the 2025 Public Domain Day Film Remix Contest Winners & Honorable Mentions

Virtual Public Domain Day Celebrates 1929 Creative Works & 1924 Sound Recordings

Public Domain Spotlight: Singin' in the Rain

More posts

New to the Archive?

How to search the archive

How to download files

Listening to music on the archive

How do I find old web pages?

Top Collections

LibriVox

Terms of Service (last updated 12/31/2014)



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



Integrity: Ensures that data is accurate, consistent, and protected from unauthorized changes or corruption.

Example: E-commerce websites need to ensure the integrity of user orders, payment information, and inventory records to prevent fraudulent transactions or errors.

Application: Using **digital signatures, encryption** for secure data transfers, and **audit trails** to monitor data changes.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



Rank 101st-200th
The WORLD UNIVERSITY
RANKINGS for INNOVATION



Rank 2
in the Philippines

AppliedHETM
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

ZoomInfo

- Purpose: Business database. Use: Provides detailed contact information for businesses and professionals. It's useful for market research, sales leads, and business intelligence.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



AppliedHE™
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

Confidentiality: Ensures that data is not exposed to unauthorized parties, maintaining privacy.

Example: Healthcare systems safeguarding sensitive patient information, such as diagnoses or treatment plans, from being accessed by unauthorized individuals.

Application: Using **encryption** to secure stored data and data in transit, and applying **access control policies** to restrict who can view specific information.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



Rank 101st-200th
The WORLD UNIVERSITY
RANKINGS for INNOVATION



Rank 2
in the Philippines

AppliedHE™
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

Dark Web Monitor

Purpose: Dark web monitoring tool.

Use: Alerts you if your personal information is found on the dark web, helping you take action to protect your identity.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



Rank 101st-200th
The WORLD UNIVERSITY
RANKINGS for INNOVATION



Rank 2
in the Philippines

AppliedHETM
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

Nonrepudiation: Ensures that a party cannot deny the authenticity of their actions or transactions, providing proof of participation.

Example: Digital contracts signed with electronic signatures, where a person cannot deny having signed the agreement.

Application: Using digital signatures, blockchain technologies, and audit trails to ensure actions or transactions cannot be denied by the involved parties.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



Rank 101st-200th
The WORLD UNIVERSITY
RANKINGS for INNOVATION



Rank 2
in the Philippines

AppliedHE™
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

Authentication: Ensures that users or systems can be trusted based on their identity, allowing them access to data or services.

Example: Bank account logins with usernames, passwords, and **one-time passcodes** sent via SMS or email for additional verification.

Application: Implementing **multi-factor authentication (MFA)**, **single sign-on (SSO)**, and **secure login protocols** (e.g., OAuth).



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



AppliedHE™
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs

Observe

- According to <Last Name> (2018), observing is a way of life.



MMSU



Rank 601-800 in the World
Rank 3 among Philippine SUCs



AppliedHE™
PUBLIC UNIVERSITY RANKING: ASEAN 2024
RANK 2 AMONG PHILIPPINE SUCs



Get in Touch With Us

Send us a message or
visit us

City of Batac, Ilocos Norte,
Philippines

(63) 77-600-0459
op@mmsu.edu.ph

Follow us for updates

 facebook.com/MMSUofficial
 www.mmsu.edu.ph

Cultivating Minds, Transforming Futures

1. Confidentiality

Objective: Ensure that sensitive information is accessible only to authorized individuals.

Common Threats:

- **Unauthorized access** (e.g., hacking, phishing attacks)
- **Data leaks or eavesdropping** (e.g., unencrypted communications)

Countermeasures:

- **Encryption:** Use strong encryption protocols (e.g., AES, TLS) for data at rest and in transit to protect against interception.
 - **Access Controls:** Implement role-based access control (RBAC) to limit who can view sensitive data. Use the principle of least privilege (POLP).
 - **Data Masking:** Hide sensitive information in environments where full data visibility is unnecessary (e.g., testing environments).
 - **Network Segmentation:** Separate sensitive systems from less critical ones to minimize access vectors.
-

2. Integrity

Objective: Ensure that information remains accurate, complete, and trustworthy.

Common Threats:

- **Data manipulation** (e.g., malicious edits to databases)
- **Transmission errors** (e.g., corruption of data during transfer)

Countermeasures:

- **Cryptographic Hashing:** Use hashes (e.g., SHA-256) to verify that data has not been altered.
- **Digital Signatures:** Authenticate the source of data and ensure its integrity during transmission.

- **Audit Trails and Logs:** Maintain detailed logs to detect unauthorized changes. Regularly monitor and validate these logs.
 - **Redundancy:** Implement redundant storage systems (e.g., RAID configurations) to preserve data integrity.
-

3. Availability

Objective: Ensure systems and data are accessible when needed.

Common Threats:

- **Denial-of-service (DoS) attacks or Distributed Denial-of-Service (DDoS) attacks**
- **System failures due to hardware issues or natural disasters**

Countermeasures:

- **Redundancy and Failover Systems:** Use backup servers, data replication, and load balancers to ensure availability during outages.
 - **DDoS Mitigation Tools:** Deploy traffic filtering and rate-limiting to prevent attacks from overwhelming systems.
 - **Regular Backups:** Schedule frequent backups and store them in secure, geographically distributed locations.
 - **Disaster Recovery Plans:** Develop and test recovery strategies to resume operations quickly after an incident.
-

4. Authentication

Objective: Ensure that users and systems are who they claim to be.

Common Threats:

- **Impersonation attacks (e.g., stolen credentials)**
- **Weak or compromised passwords**

Countermeasures:

- **Multi-Factor Authentication (MFA):** Require multiple forms of verification (e.g., password + biometrics) to confirm identity.
 - **Strong Password Policies:** Enforce the use of complex passwords and regular password rotation.
 - **Biometric Authentication:** Use fingerprints, facial recognition, or voice recognition for additional security.
 - **Session Management:** Limit session durations and use secure cookies to prevent unauthorized access after login.
-

5. Non-repudiation

Objective: Ensure that an individual or entity cannot deny actions or transactions they performed.

Common Threats:

- **Users denying that they sent data or initiated actions (e.g., fraudulent denial of sending a message or completing a transaction).**

Countermeasures:

- **Digital Signatures:** Bind a sender's identity to the message to prevent them from denying their involvement.
 - **Public Key Infrastructure (PKI):** Use certificates and keys to ensure the authenticity of transactions.
 - **Transaction Logs:** Maintain detailed records of all actions and ensure that logs are tamper-proof.
 - **Time Stamping:** Use trusted third-party time stamping to validate the date and time of actions.
-

Integrated Countermeasures

Many threats target multiple aspects of the MSR model simultaneously. For example, a ransomware attack compromises Confidentiality, Integrity, and Availability. Therefore, effective countermeasures often overlap.

Examples of Integrated Countermeasures:

- **Intrusion Detection and Prevention Systems (IDPS): Monitor network traffic for suspicious activities that might compromise multiple MSR elements.**
- **Zero Trust Architecture: Assume no user or system is trusted by default, enforcing strict authentication and access controls.**
- **Regular Security Audits: Conduct periodic evaluations of systems and policies to identify vulnerabilities.**

CIA Triad Analogy

Imagine a **house** where protecting the valuables inside is the primary goal:

1. **Confidentiality:**
This is like having locks, curtains, or a security system to ensure **only authorized people** (e.g., homeowners) can enter or see inside the house. It prevents snooping or access by outsiders.
 - Example: A burglar alarm ensures unauthorized entry is detected.
2. **Integrity:**
This is like making sure the house's structure (walls, roof, plumbing) is **well-maintained** and nothing inside the house (like your furniture or documents) is tampered with or damaged.
 - Example: Checking that important family documents remain unchanged and unaltered.
3. **Availability:**
This ensures the house and its amenities (like water, electricity, internet, or even access to the door) are **always accessible** when needed.
 - Example: Ensuring you have a spare key so you can enter the house even if you lose your main key.

MSR Model Analogy

Now, let's expand the analogy to the **MSR model**, which goes beyond the CIA Triad by addressing more dimensions of security. It looks at:

- **Goals:** What we are trying to achieve (Confidentiality, Integrity, Availability).
- **Information States:** Where and how information is processed (Storage, Transmission, Processing).
- **Safeguards:** The methods to ensure security (Policies, Procedures, Practices, Technologies).

1. **Goals (CIA):**

These are the same as above, ensuring the house is private, safe, and usable.

2. **Information States:**

These correspond to different points where security measures apply:

- **Storage:** Imagine your valuables are locked in a **safe inside the house**. Security focuses on protecting them while at rest.
- **Transmission:** This is like securely **sending valuables to a bank** or transferring them to another house. It ensures safety while in transit.
- **Processing:** This is like when you are actively using your valuables, like **opening the safe** to retrieve documents or counting cash. Security ensures nothing goes wrong during this process.

3. **Safeguards:**

These are the strategies and tools used to protect your house and valuables:

- **Policies:** The rules you set (e.g., “Always lock the door at night”).
- **Procedures:** The steps you take (e.g., double-check the alarm system before leaving).
- **Practices:** Your habits (e.g., never sharing your house keys with strangers).
- **Technologies:** Tools like smart locks, cameras, and fireproof safes.

Summary

- The **CIA Triad** focuses on *what* to protect (confidentiality, integrity, availability). It's like saying, “I want to ensure my house is private, secure, and always accessible.”
- The **MSR Model** looks at security more comprehensively, considering *where* security applies (storage, transmission, processing) and *how* to protect it (policies, procedures, technologies). It's like creating a detailed blueprint for the house and planning how to protect it during different activities

Lecture 3: The IAAA, Assets, Threats, Vulnerabilities, Risks and Controls

Understanding IAAA in Cybersecurity

Introduction: Why Cybersecurity Needs IAAA

Securing systems isn't just about setting a strong password—it's about making sure only the right people have access, at the right time, with the right permissions, and keeping track of their actions. This is where **IAAA** comes in.

IAAA stands for:

1. **Identification** – Who are you?
2. **Authentication** – Prove it!
3. **Authorization** – What can you do?
4. **Accountability** – Let's keep a record.

From social media logins to high-security banking systems, IAAA is everywhere. Without it, hackers could easily impersonate users, access sensitive data, or cover their tracks after an attack.

Imagine you're the ruler of a mighty **castle** 🏰, and your goal is to protect your kingdom from invaders.

User – a person who uses or operates something, especially a computer or other machine.

Identity – Who you claim to be.

Battling a Hacker in Real Life: The Cybersecurity War Zone

Now, let's shift gears to a **real-world cyber attack scenario**.

The Attack: A Hacker Targets a Financial Institution

You work as a security analyst for a **major bank**. One day, you receive an alert:

 **A hacker is trying to break into the system!**

Identification – Who is Accessing the System?

 **Threat detected:** An unknown IP address attempts to log in using an executive's credentials.

 **Defense:** The system **identifies** the login attempt and flags it for review.

Authentication – Are They Really the Executive?

 **Warning:** The hacker is using stolen credentials, but doesn't have the **multi-factor authentication (MFA)** device.

 **Defense:** The system **denies access** because the hacker **can't authenticate** with the second factor (e.g., an OTP from Google Authenticator).

Authorization – Restricted Access Saved the Day!

 **Attack Continues:** The hacker gains access using **another compromised employee account** but finds they have **limited access** due to Role-Based Access Control (RBAC).

 **Defense:** Because of **authorization rules**, they **can't access sensitive financial data**.

Accountability – Tracing the Intruder's Steps

 **Aftermath:** The security team reviews **logs from the SIEM system** (e.g., Splunk). They track the hacker's movements and find the source of the breach.

 **Defense:** The team patches the vulnerability, forces password resets, and prevents further attacks.

 **The Outcome?** Thanks to IAAA, the bank stopped the attack **before any financial damage occurred!**

IAAA Component	Example Tools
Identification	Google Sign-In, Facebook Login
Authentication	Google Authenticator, Duo Security
Authorization	AWS IAM, OAuth 2.0, Active Directory
Accountability	Splunk, Graylog, SIEM tools

1 Identification – Who Are You?

Before granting access, the system needs to know **who** is trying to enter. This usually involves a username, email, or ID number.

✂ Example Tools:

- **Google Sign-In, Facebook Login** – Identifies users before authentication.
- **Employee ID systems** in corporate environments.

2 Authentication – Prove It!

Once you claim your identity, you need to prove you are who you say you are. Authentication methods include:

- **Something You Know** – Passwords, PINs.
- **Something You Have** – One-time passwords (OTPs), security tokens.
- **Something You Are** – Biometrics (fingerprint, face recognition).

✂ Example Tools:

- **Google Authenticator, Microsoft Authenticator** (MFA)
- **Duo Security** (Enterprise authentication)

3 Authorization – What Can You Do?

Just because someone is authenticated doesn't mean they can do anything they want. Authorization ensures they only get access to what they're allowed.

 **Example:** In a company, an intern shouldn't have the same access as the CEO.

✂ Example Tools:

- **AWS IAM (Identity & Access Management)** – Controls permissions for cloud resources.

- **OAuth 2.0 & OpenID Connect** – Used in web applications to grant specific permissions.
-

Accountability – Tracking & Logging

Once users are inside, their actions must be monitored. This helps in detecting suspicious behavior and tracking security breaches.

Example Tools:

- **Splunk, Graylog, ELK Stack** – Log analysis tools for tracking activity.
- **Security Information and Event Management (SIEM)** – Identifies anomalies in real-time.

Cybersecurity Essentials: Protecting Your Digital Bank

1. Assets: What You're Protecting

Definition: Anything valuable in your system, such as data, hardware, software, or even human resources.

- ♦ **Analogy:** Your bank's **money, gold, customer data, and vault**.
- ♦ **Cyber Example:** Personal information, credit card numbers, company databases, or servers.

2. Threats: The Bad Guys

Definition: Anything that can exploit a vulnerability to damage or steal assets.

- ♦ **Analogy:** Bank robbers, fraudsters, cybercriminals.
- ♦ **Cyber Example:** Hackers, malware, phishing, insider threats, DDoS attacks.

3. Vulnerabilities: Weak Spots in Your Defense

Definition: Flaws or weaknesses in a system that threats can exploit.

- ♦ **Analogy:** A broken bank vault lock, an unaware security guard, an employee who falls for a scam.
- ♦ **Cyber Example:** Outdated software, weak passwords, unpatched systems, human error.

4. Risk: The Potential Damage

Definition: The likelihood of a threat exploiting a vulnerability and causing harm.

- ♦ **Formula:** **Risk = Threat × Vulnerability**
- ♦ **Analogy:** If your vault lock is weak (vulnerability) and you know there's a gang of robbers in town (threat), your risk is HIGH!

◆ **Cyber Example:** If you don't update your firewall (vulnerability) and hackers are actively scanning networks (threat), you're at a HIGH risk of being attacked.

5. Controls: Your Security Measures

Definition: Safeguards or countermeasures to reduce risk and protect assets.

- ◆ **Analogy:** Security guards, CCTV cameras, motion detectors, and reinforced vault doors.
 - ◆ **Cyber Example:** Firewalls, encryption, multi-factor authentication (MFA), endpoint protection, employee training.
-

Battling a Hacker: A Real-Life Scenario

Imagine you're protecting a company's database from a cyberattack:

- ◆ **Assets:** Customer records, company files, financial data.
 - ◆ **Threats:** Hackers using phishing emails to steal credentials.
 - ◆ **Vulnerabilities:** Employees using weak passwords, lack of MFA.
 - ◆ **Risk:** A hacker could access sensitive data, leading to financial and reputational damage.
 - ◆ **Controls:** Strong passwords, MFA, security awareness training, and endpoint protection.
-

Tools & Websites for Cybersecurity Controls

✓ Firewalls & Endpoint Protection:

- Fortinet, Palo Alto Networks, Cisco Firepower
- Windows Defender, CrowdStrike Falcon

✓ Threat Detection & SIEM:

- Splunk, IBM QRadar, ELK Stack

✓ Vulnerability Scanners:

- Nessus, OpenVAS, Qualys

✓ Risk Management:

- NIST Cybersecurity Framework
- ISO 27001 Compliance Tools

✓ Security Awareness Training:

- KnowBe4, Cybersecurity & Infrastructure Security Agency (CISA)

LECTURE 4: INFORMATION SECURITY

OBJECTIVES

- Define information security
- Know the history of computer security and its evolution to information security
- Information security planning and governance

History of Information Security

1960s - The Foundation of Information Security

- **Time-Sharing & ARPANET:** The U.S. Advanced Research Projects Agency Network (ARPANET) early computing focused on time-sharing systems, but security was minimal.
- **1967:** The first conference on computer security was held, discussing the need for data protection.

1970s - The Birth of Modern Cryptography & Early Hacking Culture

- **1973:** IBM developed the **Data Encryption Standard (DES)**, later adopted by the U.S. government.
- **1976:** Whitfield Diffie & Martin Hellman introduced **public-key cryptography**, revolutionizing secure communication.
- **1979:** The first **computer worm**, created by John Shoch, emerged at Xerox PARC.

1979 - RAND Report R-609:

- One of the first documents to define the concept of **computer security**.
- Introduced key cybersecurity principles still in use today.
- Discussed **unauthorized access, intrusion detection, and countermeasures**.

- **Late 1970s: Phone Phreaking** became popular, with hackers like **John Draper (Captain Crunch)** exploiting telephone networks.

1980s - The Rise of Computer Viruses & Hacker Culture

- **1983:** The term "**hacker**" became mainstream after the movie *WarGames*.
- **1984:** The hacker group **Legion of Doom (LOD)** emerged, influencing early hacking culture.
- **1986:** The **Computer Fraud and Abuse Act (CFAA)** was enacted in the U.S. to criminalize hacking.
- **1988:** The **Morris Worm**, one of the first large-scale cyberattacks, spread across the internet.
- **1989:** The **Chaos Computer Club (CCC)**, one of the world's oldest hacking groups, made headlines for exposing security flaws.

1990s - The Rise of Cybercrime, Anonymous Browsing, & Underground Internet Groups

- **1990:** The **Electronic Frontier Foundation (EFF)** was founded to advocate for digital rights.
- **1991:** Phil Zimmermann developed **Pretty Good Privacy (PGP)** for secure email encryption.
- **1993:** The **first web browser (Mosaic)** was released, increasing internet accessibility.
- **1994:** The first **e-commerce transaction** was conducted securely via SSL encryption.
- **Mid-1990s:** The emergence of **decentralized servers**, paving the way for the **Deep Web** and later, the **Dark Web**.
- **1999:** The **Melissa Virus** spread via Microsoft Word macros, demonstrating the risks of email-based malware.

2000s - The Era of Cyber Warfare, Hacktivism & Enigmatic Puzzles

- **2000:** The **I Love You Virus** infected millions of computers worldwide via email.
- **2001:** The **Patriot Act** expanded government surveillance powers in response to 9/11.
- **2003:** The **Anonymous movement** was formed on **4chan**, later becoming a global hacktivist group.
- **2003:** The **SQL Slammer worm** infected thousands of servers in minutes.
- **2006:** The infamous **Cicada 3301 puzzle** first appeared, an elaborate cryptographic scavenger hunt that remains unsolved.
- **2007:** **Estonia suffered a massive cyberattack**, believed to be state-sponsored.
- **2008:** The **Conficker worm** infected millions of machines, showcasing botnet capabilities.
- **2008:** The hacker group **Lizard Squad** emerged, conducting major DDoS attacks on gaming networks.

2010s - Large-Scale Data Breaches, Cyber Espionage & Mysterious Internet Challenges

- **2010:** **Stuxnet**, a highly sophisticated worm, was discovered targeting Iranian nuclear facilities.
- **2011:** Anonymous launched **Operation Tunisia**, supporting protests during the Arab Spring.
- **2012:** The **Cicada 3301 puzzle** resurfaced, fueling speculation about government involvement.
- **2013:** The **Yahoo data breach** affected 3 billion accounts.
- **2013:** The **Silk Road (Dark Web marketplace)** was taken down by the FBI.
- **2014:** The **Sony Pictures hack** was attributed to North Korea.
- **2015:** The **Hacking Team Leak** revealed governments using spyware to monitor journalists and activists.
- **2016:** The **DNC email leak** influenced the U.S. presidential elections.
- **2017:** The **WannaCry ransomware attack** exploited Windows vulnerabilities, spreading globally.

- **2018:** The **Cambridge Analytica scandal** revealed large-scale Facebook data harvesting.
- **2019:** AI and **deep learning-based cybersecurity** solutions began gaining traction.

2020s - The Expansion of Zero-Trust, AI-Powered Security & Quantum Threats

- **2020:** The **SolarWinds attack** compromised U.S. government agencies and major companies.
- **2021:** The **Colonial Pipeline ransomware attack** disrupted fuel supply in the U.S.
- **2022:** The rise of **Zero Trust security models** became essential due to remote work.
- **2023:** **Quantum computing threats** to traditional encryption became a growing concern.
- **2024:** AI-driven **phishing detection** and **real-time threat analysis** advanced significantly.
- **Ongoing:** **Cicada 3301's mystery remains unsolved**, with new puzzles emerging sporadically.

Unit 2: Planning for Security

A. The Evolution of Information Security (Infosec)

While the history (Enigma machines and early mainframes) is behind us, the modern definition of Infosec is no longer just about "locking the server room."

Information Security is the protection of information and its critical elements, including the systems and hardware that use, store, and transmit that information. In a modern context, we view this through the **CIA Triad** and the **MSR Model**.

- **The Shift:** We have moved from **Physical Security** —> **Data Security** —> **Cybersecurity** (which includes the psychological and political aspects of data).
- **The Goal:** It's about **Risk Management**. We cannot eliminate risk; we manage it to an acceptable level that allows the business to function.

B. Policy, Standards, and Practices

In the hierarchy of security documentation, clarity is the difference between a secure environment and a legal liability.

1. The Hierarchy

- **Policy:** The "What" and "Why." High-level statements of intent (Executive level).
- **Standards:** The "Must." Mandatory requirements or configurations (Managerial level).
- **Practices (Procedures/Guidelines):** The "How." Step-by-step instructions (Technical level).

2. Solid Examples & Scenarios

Document Type	Example	Scenario Application
Policy	Acceptable Use Policy (AUP): "Employees shall not use corporate assets for personal financial gain."	An employee is caught mining Bitcoin on a lab computer. The AUP provides the legal basis for termination.

Standard	Password Complexity Standard: "Passwords must be 14 characters, include MFA, and rotate every 90 days."	A system admin is setting up a new SQL server. They <i>must</i> follow this standard during configuration; it is not optional.
Practice	Onboarding Procedure: "Step 1: Verify ID. Step 2: Create AD account. Step 3: Issue YubiKey."	A new HR hire starts. The IT tech follows this checklist to ensure no steps are missed, maintaining "Least Privilege."

The Scenario: The "Coffee Shop" Breach

- **Policy:** The company has a "Remote Work Policy" stating data must be encrypted.
- **Standard:** The "Encryption Standard" requires AES-256 bit encryption for all laptops.
- **Practice:** The "Mobile Device Procedure" dictates that users must toggle the VPN *before* accessing email.
- **The Result:** An employee loses a laptop at a cafe. Because the **Practice** was followed (VPN/Encryption), the **Policy** was upheld, and the company avoids a multi-million dollar data breach notification.

C. The Information Security Blueprint

The "Blueprint" is the scalable plan used to implement the security program. You don't just "do" security; you build it using a framework.

1. The Frameworks (The Foundation)

You cannot build a house without a blueprint. In Infosec, we use:

- **ISO/IEC 27001:** The international gold standard for Information Security Management Systems (ISMS).
- **NIST Cybersecurity Framework (CSF):** Identify, Protect, Detect, Respond, Recover.

2. The Defense in Depth (The Strategy)

A key part of the blueprint is **Layered Security**.

- **Example:** Imagine a bank. You have a perimeter fence (Firewall), a security guard (IDS/IPS), a locked vault door (Encryption), and a security camera (Logging/Auditing). If one layer fails, the next one protects the asset.

3. Security Education, Training, and Awareness (SETA)

The blueprint is useless if the people don't know how to use it. SETA aims to turn the "human firewall" from the weakest link into a strong defense.

- **Example:** A blueprint for a University might include a mandatory phishing simulation every semester for all faculty.
-

Part B: Policy, Standards, and Practices (The Governance Framework)

In a high-level organization, security is a **governance** issue, not a "tech" issue. We use the **Information Security Governance Framework** to ensure that the "tone at the top" (the CEO/Board) translates into bits and bytes.

1. The Policy Taxonomy

We categorize policies into three functional types:

- **EISP (Enterprise Information Security Policy):** The "Constitution" of the org. It sets the strategic direction and assigns resources.
- **ISSP (Issue-Specific Security Policy):** Focuses on specific technologies (e.g., Cloud Computing, AI Use, Social Media).
- **SysSP (System-Specific Security Policy):** Technical specifications for a particular system (e.g., Firewall Access Control Lists or Database configurations).

2. The "Enforcement Gap" Scenario

The Scenario: A University (like yours) implements a **Bring Your Own Device (BYOD) Policy**.

- **The Standard:** All mobile devices accessing school email must have "Remote Wipe" capabilities enabled.
- **The Practice:** IT installs a Mobile Device Management (MDM) profile on student/faculty phones.
- **The Conflict:** A faculty member's phone is stolen. IT wipes the phone, but the faculty member loses 5 years of personal family photos and sues the University.

- **The Lesson:** Without a clearly signed **Policy** that outlines "Consent to Wipe," the **Standard** and **Practice** become legal liabilities. Governance must balance security with privacy laws.

Part C: The Information Security Blueprint (Architectural Design)

A blueprint is the **implementation of a security model**. If the model is the "idea" (like the CIA Triad), the blueprint is the "architectural drawing."

1. Theoretical Models (The "Why" behind the Blueprint)

To build a high-level blueprint, you must choose a mathematical or logical model:

- **Bell-LaPadula (Confidentiality):** "No read up, no write down." (Used in military/government to prevent data leaks).
- **Biba Integrity Model:** "No read down, no write up." (Used in finance/research to ensure data is never corrupted by low-integrity sources).
- **Clark-Wilson:** Focuses on separation of duties to prevent internal fraud.

2. The "Sphere of Use" Example

A blueprint must address two domains:

1. **Information in Storage (At Rest):** Database encryption, physical vaulting.
2. **Information in Transit (In Motion):** TLS/SSL, VPNs, secure protocols.

Scenario: A Health-Tech Startup Blueprint

Imagine a company building an app for patient records. Their blueprint must integrate:

- **NIST CSF (The Framework):** To identify what data they have.
- **ISO 27001 (The Standard):** To get certified so hospitals trust them.
- **HIPAA (The Regulatory Requirement):** To avoid massive federal fines.
- **The Design:** They implement a "Zero Trust" architecture—where the blueprint assumes the internal network is already compromised, requiring every user to re-verify identity at every single step.

III. Summary Table: The "Gold Standard" Breakdown

Level	Component	Focus	Harvard Business Insight

Strategic	Policy	Why do we care?	Aligns security with the business mission.
Tactical	Blueprint	How do we build it?	Provides a scalable roadmap for growth.
Operational	Practices	What do we do daily?	Ensures consistency and reduces human error.